As we've seen in earlier chapters, ACME already relied on policy-based authorization to control access across its Customer Collaboration platform, internal systems, and APIs. Policies were evaluated by shared policy engines at runtime and managed through review and testing. Still, policy work remained challenging. Engineers found it hard to understand the impacts of policy changes. Policy owners wanted clearer explanations of why access was allowed or denied. Security reviews often revealed edge cases that no one had predicted.

Early experiments with AI showed promise. Teams asked AI tools to explain policies, summarize rules, and explore hypothetical access situations. This chapter explores how ACME reshaped its approach. We look at how AI supports policy creation and analysis without influencing enforcement, how AI can show what policies actually do in practice, and how authorization must be applied to AI-powered systems like retrieval-augmented generation (RAG). The main idea is simple. AI should be part of the policy process, not the final decision point. When used this way, it enhances security, boosts policy quality, and increases accountability.

17.1 AI is not your policy engine

Once AI tools became part of ACME's daily workflows, it was only a matter of time before someone asked the obvious question: if an AI system can explain policies, summarize rules, and reason about access scenarios, why not let it make authorization decisions directly?

The idea appeared in several places. One prototype support chatbot embedded access rules directly into its prompt, instructing the AI to decide whether to display internal documents based on conversational context and a textual description of company policy. Another internal tool tested prompting an AI assistant to determine whether an engineer's request "seemed reasonable," given a summary of their role and recent activity. In each case, the goal was efficiency. If AI could reason about intent from context and instructions, maybe it could make enforcement simpler.

In these early prototypes, access was no longer controlled by policy but inferred from text embedded in prompts. This method quickly encountered